

Winning the Mastercard "AI Defense Lab for Payment Security" @ GFF 2026: Strategy + Technical Playbook

TL;DR

Win by building the one thing the median team can't: a closed-loop adversarial system where a feedback-driven attacker agent evolves against your detector, fused with a multimodal deepfake-detection stream (your published edge) and a graph/mule-network layer — demoed live against a sandboxed mock ISO 8583/UPI API, framed in Mastercard's own vocabulary (Decision Intelligence, Agentic Tokens, Consumer Fraud Risk). Most teams will ship XGBoost-on-ULB + Streamlit; that scores mid-pack on every judging axis.

Anchor novelty in the 2026 agentic-commerce attack surface (AP2 mandate forgery, Mastercard Agent Pay/Agentic Tokens scope-creep, indirect prompt injection into shopping agents — a real, documented 2025-26 vector) because it is under-explored, sponsor-relevant, and lets you demo an attack→catch loop no tabular model can.

Spend your 40-80 hours on the loop, the multimodal fusion, and evaluation rigor (PR-AUC, recall@fixed-FPR, TSTR fidelity, latency budget) — not on scraping attack lists or hand-tuning a classifier. Cut the RL attacker to a scripted evolutionary attacker if time runs short.

Key Findings

1. The obvious/median submission (what to beat). The default pipeline is: prompt an LLM for a list of attack types → generate fake transactions with Faker/CTGAN → train XGBoost on the ULB credit-card dataset → wrap in Streamlit. This is generic on all five judging axes (diversity, fidelity, detection efficacy, novelty, feasibility). It uses a 2013, PCA-anonymized, two-day European dataset (284,807 txns, 0.172% fraud) whose 28 features are opaque principal components — impossible to reason about as "real payment behavior," which the brief explicitly rewards.

2. Agentic commerce is the highest-novelty vein for 2026 and it is sponsor-central. Mastercard launched Agent Pay on April 29, 2025 (Agentic Tokens + Verifiable Intent), piloted with Citi and US Bank in September 2025, reaching all US cardholders in November 2025. Google's AP2 (Agent Payments Protocol, announced September 16, 2025, 60+ partners incl. Mastercard) uses three signed W3C Verifiable Credential "Mandates" (Intent, Cart, Payment). Visa's Trusted Agent Protocol (Oct 14, 2025, with Cloudflare) signs agent identity into HTTP headers. OpenAI/Stripe/Meta's Agentic Commerce Protocol (ACP) issues single-use amount-capped tokens. These open a genuinely new fraud surface with documented real-world exploitation. [Visa](#)

↗
[Concordium](#)

↗
3. Indirect prompt injection against shopping/payment agents is real and documented, not hypothetical. Palo Alto Unit 42, Zscaler ThreatLabz, and Forcepoint X-Labs all published in-the-wild cases in 2025-26 of malicious web content that hijacks AI agents into making or redirecting payments. This is a defensible, demonstrable attack you can safely simulate in a sandbox.

4. India rails and Mastercard framing matter for GFF Mumbai. RBI's FY2024-25 Annual Report recorded 13,516 digital-payment-fraud cases (56.5% of all reported banking frauds). RBI/RBIH are deploying

MuleHunter.AI (onboarded by 29 banks) and the Digital Payments Intelligence Platform (DPIP, 7-bank pilot). Digital-arrest and UPI collect-request fraud are dominant typologies; NPCI permanently blocked P2P collect requests from October 1, 2025. This is the vocabulary the Mastercard AI Garage judges live in.

5. Your deepfake-detection publication is a moat. The attacks in scope are increasingly deepfake voice/video/document (Arup: US\$25.6M across 15 wire transfers, February 2024, reported by CNN/SCMP). A defense that scores the *social-engineering channel* (audio-deepfake + liveness/injection detection) and fuses it with a transaction-risk stream is a differentiator few teams can credibly build — and you have peer-reviewed expertise plus permissively-usable datasets (ASVspoof, In-the-Wild, FaceForensics++) to do it fast.

Details

(A) Attack-vector landscape — the map to put in the "Identify" pillar

Organize the deck's attack taxonomy by surface. Breadth + grounding is explicitly rewarded, so present a wide matrix, each row tagged with a real incident/source and the rail it hits.

A1. GenAI-supercharged social engineering / APP fraud

Deepfake video/voice CFO fraud — Arup Hong Kong, US\$25.6M (HK\$200M) across 15 wire transfers to 5 accounts, February 2024; every participant except the victim was AI-generated (confirmed by Arup CIO Rob Greig; reported by CNN May 2024 and South China Morning Post). The canonical case.

Real-time voice cloning vishing, romance/pig-butcherer run by LLM agents, BEC at scale.

Deepfake KYC / liveness bypass and injection attacks — feeding synthetic video into onboarding via virtual cameras (distinct from *presentation* attacks; injection bypasses the camera hardware and is defended by Injection Attack Detection; presentation attacks are covered by PAD under ISO/IEC 30107-3). Per the **iProov Threat Intelligence Report 2025**, "native virtual camera attacks... increas[ed] by 2665%" and "face swap attacks surged 300% compared to 2023"; iProov's 2026 report adds that "injection attacks targeting iOS devices surged by 1,151% in the second half of 2025," contributing to a 741% annual increase. (Both are vendor-produced figures — attribute to iProov.)

Synthetic identity creation with GenAI documents + selfies. Per **Entrust's 2025 Identity Fraud Report**, digital document forgeries surpassed physical counterfeits for the first time in 2024, accounting for 57% of all document fraud detected, and the report found "a deepfake attack happened every five minutes in 2024."

A2. India-specific rails and typologies (GFF-relevant)

UPI: collect-request (pull) abuse — NPCI permanently blocked P2P collect from Oct 1, 2025; QR-code manipulation / quishing; UPI AutoPay/mandate abuse; screen-sharing/remote-access scams; UPI Lite and UPI Circle (delegated payments) as emerging surfaces. UPI now runs ~18+ billion transactions/month.

AePS / Aadhaar-enabled payments and biometric spoofing, fueled by leaked personal data (Resecurity reported 815M Indians' data for sale on the dark web, Oct 2023).

Digital-arrest scams — India cyber-fraud losses reached ₹22,845 crore in 2024 (a 206% YoY jump, per MHA data presented in Parliament); digital-arrest cases fell 86% in 2025 after I4C intervention (per ThePrint/MHA data).

Mule networks — MuleHunter.AI studied 19 mule-account behavior patterns; RBIH CEO Sahil Kini cited "roughly 90%" accuracy.

Reporting/defense frameworks: CFCFRMS, 1930 helpline, cybercrime.gov.in/CPFIR, DPIP, MuleHunter.AI.

A3. Card-not-present / card-present

BIN attacks / enumeration, automated card testing by agents, 3-DS 2.x + OTP interception, SIM swap, adversary-in-the-middle phishing kits (EvilProxy-style) defeating OTP/2FA, digital-wallet provisioning

fraud, refund/chargeback + first-party ("friendly") fraud, and Magecart skimming. Per Mastercard (2026, citing Recorded Future's annual payment fraud report): "there were 10,500 such hacks active in 2025, leading to the compromise of over 23 million online transactions."

A4. Agentic-commerce attack surface (the novelty core)

Protocols/standards to name: Google AP2 (Intent/Cart/Payment mandates as W3C Verifiable Credentials); Mastercard Agent Pay + Agentic Tokens + Verifiable Intent; Visa Trusted Agent Protocol; OpenAI/Stripe/Meta ACP; x402 (HTTP 402 stablecoin settlement; x402 Foundation launched under the Linux Foundation, July 14, 2026); MCP.

Scale context: Per Visa's Oct 14, 2025 press release, there was a "4,700% surge in AI-driven traffic to U.S. retail sites," and Visa projects that by 2028, 25% of all digital storefront interactions will be initiated by AI agents.

New fraud modes: indirect prompt injection via merchant pages (Unit 42, Zscaler, Forcepoint documented in the wild; a public red-teaming competition logged 1.8M injection attempts with 60,000+ successful policy violations; Google observed a 32% rise in malicious injection payloads Nov 2025–Feb 2026); mandate/intent forgery; agent impersonation; VC/mandate replay; agent-to-agent collusion; over-authorization/scope creep (Mastercard's own framing: even a well-behaved agent buying outside intended scope is "functionally indistinguishable from fraud"); confused-deputy attacks; bot traffic indistinguishable from human.

x402 caveat worth flagging: transactions are non-reversible by design — no chargeback path — which changes the fraud calculus vs card rails (contrast with Mastercard Agentic Tokens and OpenAI Shared Payment Tokens, which preserve dispute rights).

A5. Adversarial ML against the detection stack itself

Evasion (white/black-box), gradient-free query attacks, data poisoning of retraining loops, concept-drift exploitation, model inversion, and RL attackers that learn the detector's boundary. Prior art: "Adversarial Learning in Real-World Fraud Detection" (arXiv 2307.01390); RL-based evasion GANs (RELEVAGAN, arXiv 2210.02840) — directly transplantable framing for your closed loop.

A6. LLM scaling factors

Cheap multilingual scam localization (critical for India's languages), automated OSINT victim profiling, scam-as-a-service (FraudGPT/WormGPT since July 2023, subscriptions ~\$60-700/mo per SlashNext; successors like Xanthorox surfaced April 2025). Note honestly: security researchers (Netenrich, Tanium) assess many of these as overhyped repackaged jailbreaks — cite them as a capability trend, not a magic weapon.

(B) Architecture, differentiation, and what looks generic

Recommended architecture (the "AI Defense Lab"): a genuine closed loop with three fused defense streams.

Attacker agent (Generate pillar). An LLM- or evolutionary-search-driven attacker that generates synthetic attack transactions/sequences, receives the detector's score as feedback, and iteratively mutates until it evades — then the detector retrains on the evasions. Metrics that make this rigorous and demo-able: attack success rate over generations, time-to-evasion, detector robustness curve, coverage of the attack space. This is the single biggest differentiator and maps directly to "novelty" + "fidelity" + a live demo.

Trade-off / fallback: a full RL attacker (DQN/PPO over a feature-perturbation action space) is high-risk in 40-80 hours. Ship a **scripted evolutionary/genetic attacker** (mutation + selection against detector score) first; it produces the same evasion curves with far less risk. Upgrade to RL only if the loop works early.

Multimodal detection matched to the attacks (your moat). Fuse (a) a **transaction-risk stream** (gradient-boosted trees baseline + graph features) with (b) a **social-engineering-channel stream**: audio-deepfake detection (ASVspoof 2019/2021, In-the-Wild), face-forgery (FaceForensics++), document-forgery scoring. A late-fusion meta-classifier outputs a single risk score. This is defensible because you have a peer-reviewed deepfake-detection paper (Computers & Security, Elsevier).

Drop-in models/datasets: AASIST/SSL front-ends for audio (ASVspoof); FF++ for face. Note licensing (FF++ and DFDC require agreeing to research-use terms; ASVspoof/In-the-Wild are research-permissive).

Graph/mule-network layer. A GNN or temporal graph layer over money-flow graphs catches coordinated attacks tabular models miss and directly echoes MuleHunter.AI. Use IBM AMLworld (up to 175-180M txns, 8 laundering patterns, perfect labels, on Kaggle, CDLA-Sharing-1.0) or AMLSim to generate mule topologies (fan-in/out, cycle, scatter-gather). Benchmark evidence: graph methods beat tabular by ~10-15 AUC points on YelpChi/Amazon.

Agentic-payment protocol defense (the "wow" demo). Implement a minimal AP2-style mandate flow (Intent/Cart/Payment as signed credentials) against a **mock** payment API; show an attacker forging/replaying a mandate or exploiting scope creep, and your verifier catching it (signature check, expiry, scope/limit enforcement, anomaly detection on agent behavior). AP2 samples are Apache-2.0 and run without a live payment provider — ideal for a safe, impressive prototype.

Why not the alternatives (be decisive):

Pure agent-based ecosystem simulator (ABIDES/Mesa-style) — highest fidelity, but too much build cost for 80 hours; borrow AMLSim/AMLworld outputs instead of building a simulator from scratch.

Deep tabular SOTA (FT-Transformer/TabNet/TabPFN) — rarely beats well-tuned LightGBM/CatBoost on tabular fraud; not worth the time. Use GBDT as the transaction baseline and spend novelty budget on the loop + fusion.

Evaluation rigor as a differentiator (map explicitly to judging criteria):

Detection efficacy → PR-AUC (not just ROC-AUC — extreme imbalance makes ROC-AUC flattering), recall@fixed-FPR, precision@k (alert-review budget), F1, calibration.

False positives on legit payments → cost-sensitive metric (money saved vs FP friction), FPR at operating threshold.

Fidelity of simulation → TSTR (train-on-synthetic-test-on-real), marginal + correlation similarity, and a privacy check (DCR / nearest-neighbor distance ratio). Note the known TSTR pitfall (synthetic-float vs real-int type mismatch zeroing out predictive power).

Real-world feasibility → authorization-time latency budget (Mastercard's DI Pro scores "in less than 50 milliseconds"; state your model's inference latency), ISO 8583 / ISO 20022 message-level decisioning, integration points (issuer authorization, 3DS ACS RBA, network scoring), explainability/adverse-action, model governance, RBI fraud-monitoring expectations, PCI-DSS data minimization.

Synthetic-data generation choice under time pressure: For transaction fidelity, **CTGAN/TVAE (SDV) as baseline, TabDDPM (diffusion) for the fidelity headline** — TabDDPM beats GAN/VAE on most benchmarks and gives strong DCR/privacy numbers, though note SMOTE is a surprisingly strong baseline. For sequences, consider GReaT (LLM-based) only if time allows. Report TSTR + marginal similarity as your fidelity evidence.

Position complementary to Mastercard's stack (name-drop with accuracy):

Decision Intelligence / DI Pro — per Mastercard (Feb 1, 2024, via CNBC/newsroom), DI already scores "143 billion transactions a year"; the new gen-AI DI Pro (a proprietary in-house RNN/transformer) scans

"one trillion data points" and, per Ajay Bhalla, President of Cyber and Intelligence, "in less than 50 milliseconds... boost[s] fraud detection rates by 20% on average and as high as 300% in some instances."

Mastercard Threat Intelligence — built on Recorded Future; Mastercard's FY2024 Form 10-K records the Recorded Future acquisition at \$2.65 billion (net assets acquired \$2,781M), integrated into Cyber & Intelligence in January 2026; Threat Intelligence launched Oct 2025 at Money20/20.

Consumer Fraud Risk (CFR) — UK APP-scam scoring; per Mastercard (Sept 24, 2024), "initial offline tests of the additional 'inbound risk' alerts have seen a 60% improvement, on average, in a bank's ability to identify high-risk mule accounts early"; CFR has helped 11 UK banks since early 2023 (later reported as ~15 banks covering ~90% of UK A2A volumes).

Also: Brighterion, Agent Pay/Agentic Tokens, Identity Check, tokenization. Frame your project as a *red/blue sandbox* that stress-tests these categories — not a replacement.

(C) Datasets and detection SOTA

Usable, permissively-licensed datasets (respecting the synthetic/anonymized/authorized-only rule):

Dataset	Size / imbalance	License	Good for	Gotchas
ULB credit-card (mlg-ulb)	284,807 txns, 0.172% fraud	DbCL v1.0	Quick imbalanced baseline	2013, PCA-anonymized, opaque features; don't build the story on it
IEEE-CIS	590,540 CNP txns, 3.5% fraud, 431 features	Kaggle competition	Realistic feature-rich CNP	Competition-license redistribution limits
PaySim	~6.36M mobile-money txns, ~0.13% fraud	CC BY-SA 4.0 (re-verify on Kaggle)	Closest legit UPI-like mobile-money proxy	Balance columns cause label leakage
Sparkov / Kartik Shenoy	1,852,394 txns, ~0.52% fraud, 2019-2020	CC0 1.0	Human-readable synthetic cards	Faker-generated; simplistic distributions
IBM TabFormer	~24M synthetic card txns	Verify repo LICENSE	Sequence/time-series modeling	Data license not explicitly confirmed
IBM AMLworld (Kaggle)	up to 175-180M txns, 8 laundering patterns	CDLA-Sharing-1.0	Graph/mule detection, perfect labels	Large; needs preprocessing
Elliptic / Elliptic++	203,769 nodes, 234,355 edges, ~2% illicit	Research use	Temporal graph fraud	Bitcoin, not cards
ASVspooof 2019/2021, In-the-Wild	100k-680k+ utterances	Research-permissive	Audio-deepfake stream	Check per-corpus terms
FaceForensics++ / DFDC	5,000 / 128,154 videos	Research EULA (must apply)	Face-forgery stream	Redistribution prohibited

No high-quality, validated UPI-specific fraud dataset exists. Kaggle UPI datasets (e.g., skullagos5246's "UPI Transactions 2024," maulikgajera's ~20k-row set) are synthetic, hobbyist-grade, and unvalidated against NPCI/RBI data. Use PaySim as the legitimate mobile-money proxy (it is itself derived from an African mobile-money service, structurally similar to UPI's wallet/P2P model) and generate UPI-flavored synthetics yourself; state this limitation openly.

Detection SOTA / practical baselines:

Tabular: well-tuned LightGBM/CatBoost/XGBoost remain the practical winners; deep tabular models (FT-Transformer, TabNet, TabPFN v2) rarely beat them on fraud tables.

Graph: GCN/GAT/PC-GNN/GTAN beat feature-only models by ~10-15 AUC points (Cheng et al. 2024 benchmark: YelpChi MLP 0.732 → PC-GNN 0.892).

Sequence: transformer-over-history (TabBERT-style) for behavioral drift.

Unseen-attack case: anomaly detection / autoencoders for zero-day attacks the classifier hasn't seen — important because your attacker agent generates novel evasions.

Hybrid rules+ML is what actually ships in production.

Forkable/legit-to-build-on: SDV (CTGAN/TVAE, MIT), TabDDPM (source released, ICML 2023), AMLSim (Apache-2.0), IBM AML-Data (CDLA), Visa Trusted Agent Protocol sample (GitHub), Google AP2 samples (Apache-2.0), ASVspooof baselines. Respect each license and keep attribution.

(D) 15-day execution plan (40-80 person-hours, 2-3 people, deadline Aug 31)

Roles: Lead (you) — closed loop + multimodal fusion + deck narrative; Eng2 — data generation + detection models + graph layer; Eng3 (if present) — web prototype UI + mock payment API + demo.

Days 1-2 (Identify): Lock the attack taxonomy matrix (A1-A6 above), each row sourced. Draft deck skeleton. Decide scope: transaction loop + deepfake fusion + AP2 mandate demo (drop graph layer first if 2-person team).

Days 3-5 (Generate): Build synthetic transaction generator (SDV baseline + TabDDPM for the fidelity headline). Stand up the mock payment API (ISO-8583-ish fields + AP2 mandate flow). Wire the scripted evolutionary attacker.

Days 6-8 (Defend v1): LightGBM transaction baseline + PR-AUC/recall@FPR harness. Integrate audio-deepfake model (pretrained ASVspooof) and face-forgery model as the second stream; late-fusion meta-classifier.

Days 9-10 (Closed loop): Connect attacker→detector→retrain. Produce evasion curve, time-to-evasion, robustness curve. Add graph/mule layer if on schedule.

Days 11-12 (Prototype): Web UI showing the loop live: attacker evolving, detector catching, a forged AP2 mandate being blocked, metrics dashboard. Keep UI presentable, not fancy.

Days 13-14 (Deck + rigor): TSTR fidelity numbers, latency measurement, feasibility slide in Mastercard vocabulary, responsible-AI/ethics slide. Reproducibility pass on the repo (README, seeds, one-command run).

Day 15: Buffer, dry-run demo, record fallback video.

What to cut, in order: (1) RL attacker → scripted evolutionary; (2) graph layer → tabular+multimodal only; (3) TabDDPM → CTGAN only; (4) live UI → recorded demo + notebook. Never cut: the closed loop, PR-AUC evaluation, and the ethics/reproducibility slides.

(E) Ethics / rules landmines (disqualification risks)

Only synthetic/anonymized/authorized data. Every dataset above qualifies; never touch real cardholder data or PII. State data provenance explicitly in the repo.

Never target live systems. Adversarial testing must hit only your **sandboxed mock payment API** — say this loudly in the deck and README.

Don't publish operational attack tooling. Redact scam scripts, keep the attacker agent parameterized on synthetic features only, and note responsible-disclosure alignment (the challenge requires responsible-AI + security-disclosure practices).

Frame red-team capability responsibly — the value is stress-testing a defense, not shipping a weapon. Cite the co-evolutionary AI framing (arXiv 2410.09066) as your ethical north star.

Recommendations

Commit now to the closed-loop + multimodal + AP2-mandate architecture. It is the only design that scores high on all five axes simultaneously and is buildable in your hours. Benchmark to change course: if

by Day 9 the attacker isn't producing measurable evasion curves, drop RL/evolutionary sophistication and ship a fixed adversarial test suite instead — still novel, lower risk.

Lead with your deepfake moat. No other team can credibly fuse a peer-reviewed deepfake-detection stream with transaction risk. Make it the centerpiece of the novelty slide.

Speak Mastercard's language throughout — DI Pro's <50 ms budget, Agentic Tokens' scope enforcement, Consumer Fraud Risk's mule scoring, MuleHunter.AI/DPIP for India. Position as complementary sandbox, not naive reinvention.

Make evaluation the proof, not an afterthought. PR-AUC, recall@fixed-FPR, TSTR, latency, and a cost-of-fraud-vs-FP-friction number are what a payments judge trusts. Threshold to escalate: if PR-AUC on a held-out (temporal-split) set is below your synthetic-trained baseline, your fidelity story is broken — fix the generator before adding features.

Protect reproducibility and ethics from Day 1 — one-command run, seeds, data-provenance and sandbox statements. These are cheap and directly hit "real-world feasibility" and the responsible-AI rules.

Caveats

Vendor/self-reported statistics (Mastercard's up-to-300% uplift and <50 ms latency, iProov's 2665%/300%/1,151% deepfake figures, Entrust's 57% document-forgery share, RBIH's ~90% MuleHunter accuracy, Visa's 4,700% agent-traffic surge and 25%-by-2028 projection) come from parties with commercial or institutional incentives; attribute them to the named source rather than stating as independent fact. The Visa 2028 figure and any forward-looking rollout milestones are projections/announcements, not realized outcomes.

Some agentic-commerce rollout dates (Agent Pay global expansion, x402 Foundation, Recorded Future January-2026 integration) are recent and evolving; cite the announcement, not a guaranteed production state.

FraudGPT/WormGPT capabilities are assessed as partly hype by security researchers (Netenrich, Tanium) — present as a trend, not a proven super-weapon.

FaceForensics++/DFDC require signing research-use agreements; confirm terms before including in a public repo. IBM TabFormer's explicit data license and PaySim's CC BY-SA 4.0 field should be re-verified on the source pages before publication.

The iProov report-year naming is a known trap: the "2025" report covers 2024 data (2665%/300%); the "2026" report covers 2025 data (1,151%/741%). Cite the correct pairing.